

GentleWoman TSD v1.0 — Technical Specification

Technical Specification Document (TSD)

GentleWoman — Headless Commerce Storefront x Odoo 19

Erajaya — Value-Added Services *Storefront (Frontend) x Odoo 19 (Backend) — Integrated Architecture*

Document Control / Kendali Dokumen

Item	Detail
Document Title	Technical Specification Document — GentleWoman Headless Commerce
Document ID	GW-TSD-001
Version	1.0
Status	Final for Approval
Classification	Confidential — Internal
Date	Juni 2026
Author / Owner	Product Owner — Value-Added Services (Erajaya)
Audience	Engineering, DevOps, Security, Architecture
Related Documents	Blueprint (GW-BP-001), FSD (GW-FSD-001), Business Presentation (GW-PRES-001)

Revision History / Riwayat Revisi

Version	Date	Author	Description
1.0	Juni 2026	Product Owner — VAS	Initial release / Rilis awal

Approval / Lembar Pengesahan

Role	Name	Signature	Date
Prepared by — Product Owner, Value-Added Services			
Reviewed by — IT Business Analyst / Technical Lead			
Approved by — Head of Value-Added Services / IT			

Catatan bahasa / Language note. Dokumen ini bilingual: narasi disajikan dalam Bahasa Indonesia dengan istilah teknis Bahasa Inggris. *This document is bilingual: narrative in Bahasa Indonesia with English technical terms.*

1. Pendahuluan / Introduction

ID. Dokumen ini menetapkan kebutuhan teknis implementasi **GentleWoman**, sebuah storefront *headless* untuk fashion commerce. Storefront dibangun dengan **Next.js 15** sebagai *frontend* dan **Odoo 19 Community Edition** sebagai *backend* (system of record) di atas Odoo Platform multi-tenant. Tujuan dokumen: menjadi acuan rekayasa, keamanan, dan operasi untuk membangun, mengintegrasikan, dan menjalankan solusi.

EN. This document specifies the technical requirements for **GentleWoman**, a *headless* fashion-commerce storefront. The storefront uses **Next.js 15** as the frontend and **Odoo 19 Community Edition** as the backend (system of record) on the multi-tenant Odoo Platform. It is the engineering, security, and operations reference to build, integrate, and run the solution.

1.1 Ruang Lingkup / Scope

- **In scope:** storefront Next.js, Backend-for-Frontend (BFF), modul Odoo `custom_storefront_api` dan modul pendukung, integrasi `ai-gateway` (AI Personal Shopper), keamanan, internasionalisasi (ID/EN), deployment & operasi untuk tenant `gentlewoman`.
- **Out of scope:** pengembangan modul platform inti yang sudah ada (lihat §3.4 Reuse), integrasi payment gateway Eraspaces (BLOCKED — lihat §13), fitur Fase 2/3 (AI Admin, Avatar/Virtual Try-On).

1.2 Referensi / References

- `docs/spec-headless-fashion-commerce-ai.md` — implementation brief (F1–F11, AI).
- `addons/ee_gap/custom_storefront_api/MODULE_KNOWLEDGE.md` — module architecture.
- Blueprint Document (GW-BP-001), FSD (GW-FSD-001).

2. Arsitektur / Architecture

ID. Desain *headless*: storefront Next.js (UI + BFF) berada di atas Odoo 19 CE sebagai sumber kebenaran tunggal, pada Odoo Platform multi-tenant. Browser **tidak pernah** berbicara langsung ke Odoo — seluruh trafik melewati BFF (server-side) yang menyuntikkan header otentikasi dan tenant.

EN. Headless design: the Next.js storefront (UI + BFF) sits over Odoo 19 CE as the single source of truth on the multi-tenant Odoo Platform. The browser **never** talks to Odoo directly — all traffic passes through the server-side BFF, which injects auth and tenant headers.

```
Browser →HTTPS (Caddy/TLS)→ Next.js Storefront (App Router)
    │
    ├── UI (React, Tailwind, Framer Motion, three.js)
    └── BFF API routes (/api/store, /api/img, /api/shopper, /api/docs)
        │
        │ server-side, TLS-pinned
        ▼
        storefront-tls (TLS sidecar) → Odoo :8069
        │
        │ Odoo modules: custom_storefront_api, custom_affiliate, custom_core,
        │ custom_ecommerce, custom_payment_id, custom_pdp_* → PostgreSQL (db: gentlewoman)
        ▲
        ai-gateway (FastAPI) — Claude / Ollama
```

- **Tenant resolution.** BFF mengirim header `X-Odoo-Database: gentlewoman; dbfilter Odoo ^%d$` mengisolasi request ke database tenant.
- **Single source of truth.** Odoo memiliki catalog, stock, price, order, customer, promotion, fulfilment, affiliate, dan editorial content.

3. Spesifikasi Komponen / Component Specifications

3.1 Storefront (Next.js, container storefront)

- **Stack:** Next.js 15 (App Router) + TypeScript; Tailwind CSS; Framer Motion; three.js + @react-three/fiber + drei (3D); Zustand (state); isomorphic-dompurify (sanitization). Build *standalone* (Node 20 Alpine, non-root, read-only FS).
- **Halaman:** Home, PLP (Product List), PDP (Product Detail), Cart, Checkout, Stores, Account (login/register/orders/wishlist/addresses/affiliate).
- **BFF route handlers:** mem-proxy ke Odoo, menyuntik auth/tenant header server-side, tidak pernah mengekspos secret ke browser; render metadata SEO/OG per produk (terlokalisasi).
- **State client:** cart, wishlist, auth (profil saja), locale, UI.

3.2 BFF & TLS Sidecar

- **BFF (/api/store , /api/img , /api/shopper , /api/docs , /api/affiliate):** batas keamanan; menyuntik Bearer dari cookie, refresh transparan saat 401, rate-limit + body cap.
- **storefront-tls :** sidecar `nginx:alpine` (TLS murni → `odoo:8069`); `lib/odoo.ts` mem-pin sertifikat (`/etc/ssl/odoo-internal.crt`) — hop internal BFF↔Odoo terenkripsi.

3.3 Modul Odoo / Odoo modules

Module	Responsibility
<code>custom_storefront_api</code>	API katalog/konten/stores publik; API customer JWT (cart, wishlist, address, order, checkout); API admin HMAC; model editorial content; field store-locator; PII-at-rest; guest checkout
<code>custom_affiliate</code>	Master afiliasi/link/klik/konversi/payout; atribusi order; public click-tracking; cron lifecycle harian
<code>custom_core</code>	Platform bersama: HMAC <code>secure_endpoint</code> ; helper enkripsi field Fernet
<code>custom_ecommerce</code> , <code>custom_payment_id</code>	Quote ongkir kurir Indonesia; adapter payment (Eraspaces stub)
<code>custom_pdp_*</code>	Dukungan data protection (klasifikasi, consent, audit, masking, retention)

3.4 Reuse — Tanpa Reinvensi / No Reinvention

ID. Sebagian besar kapabilitas sudah tersedia di platform dan digunakan ulang — ini yang menekan effort developer:

- **Cart** = draft `sale.order` `website_sale` (helper di `models/sale_order.py` membungkus `_cart_add` / `_cart_update_line_quantity` sehingga pricelist/pajak dihitung native).
- **Shipping** = `delivery.carrier.id_rate_shipment(order)` dari `custom_ecommerce`.
- **Payment** = `payment.transaction` + adapter `custom_payment_id` (Eraspace stub).
- **Encryption/HMAC** = helper `custom_core` (Fernet + secure-endpoint).
- **AI** = `ai-gateway` multi-provider (Claude/Ollama) sudah ada.

3.5 ai-gateway (sidecar)

- FastAPI; abstraksi multi-provider (Claude / Ollama lokal); router `/v1/shopper` ; HMAC-validated; rate-limit; Redis cache; prompt caching (Anthropic).

4. Model Data / Data Model (Odoo)

ID. Katalog memakai model native (`product.template` / `product.product` , `product.tag` , `product.public.category` , `pricelist`). Ekstensi storefront:

Model	Field / Entity	Keterangan
<code>product.template</code>	<code>custom_material_composition</code> (Text, translate)	Komposisi material di PDP
<code>product.template</code>	<code>custom_drop_date</code> (Date) + <code>custom_is_new</code> (computed)	Badge "New" otomatis (window default 30 hari)
<code>res.partner</code>	<code>custom_is_guest</code> , <code>custom_consent_marketing</code> , <code>custom_consent_data</code> , <code>custom_consent_date</code>	Guest + consent UU PDP
<code>res.partner</code>	<code>custom*_enc</code> (Fernet) untuk phone/street/street2/zip	PII at-rest terenkripsi (gentlewoman-only)
<code>sale.order</code>	<code>custom_affiliate_id</code> , <code>custom_is_pickup</code> , <code>warehouse_id</code>	Atribusi afiliasi + click & collect
<code>stock.warehouse</code>	<code>custom_storefront_published</code> , <code>custom_store_latitude/longitude</code> , <code>custom_store_hours</code> , <code>custom_store_image</code>	Store locator
<code>custom.wishlist</code>	(<code>partner_id</code> , <code>product_tmpl_id</code>) + opsional <code>product_id</code>	Wishlist (unique per pasangan)
<code>custom.storefront.token</code>	<code>partner_id</code> , <code>user_id</code> , <code>token_hash</code> , <code>ip_hash</code> , <code>ua_hash</code>	Refresh token (hashed)
<code>custom.storefront.content</code>	<code>code</code> , <code>eyebrow</code> , <code>headline</code> , <code>body</code> , <code>cta_*</code> , <code>image</code> (translate)	Editorial CMS block
<code>custom.storefront.subscriber</code>	<code>email</code> (unique), <code>consent</code>	Newsletter
<code>custom.affiliate*</code>	master/link/click/conversion/payout	Affiliate program

5. Permukaan API / API Surface

Public (no auth, CORS, read-only): GET

/storefront/api/{categories,products,products/<id>,products/<id>/availability,tags,stores,content}, POST .../shipping/quote, POST .../newsletter. Katalog menerima lang, tag (CSV id), price_min / price_max, category, q, sort, page, limit; respons menyertakan price_bounds {min,max}.

Customer (JWT, partner-scoped): POST /auth/{register,login,guest,refresh}, POST /auth/logout; GET /customer/me, */customer/addresses[/<id>]; GET/POST/PUT/DELETE /cart[...], POST /cart/{shipping,address,pickup}; GET/POST /wishlist, DELETE /wishlist/<tmpl_id>, POST /wishlist/<tmpl_id>/move-to-cart, POST /wishlist/move-all-to-cart; POST /checkout, POST /checkout/<id>/pay; GET /orders[/<id>].

Admin (HMAC, server-to-server): POST /admin/{health,sync/products,orders/<id>/status}.

6. Kontrak Integrasi / Integration Contracts

Aspect	Specification
Tenant header	X-0doo-Database: gentlewoman (BFF → Odoo, server-side)
HMAC scheme	X-Signature = HMAC-SHA256(secret, ascii(X- Timestamp) + raw_body) ; replay window 5 menit; secret di ir.config_parameter custom_core.secure_endpoint.storefront.secret ↔ env STOREFRONT_HMAC_SECRET
JWT	validator auth_jwt bernama storefront (HS256, aud=storefront , iss=custom_storefront_api); partner di-resolve dari email claim → request.jwt_partner_id (body partner tak dipercaya)
Access/Refresh	access TTL default 900s (custom_storefront_api.access_ttl); refresh disimpan hashed di custom.storefront.token
AI gateway	BFF → ai-gateway /v1/shopper , HMAC-signed, tenant injected server-side
CORS	custom_storefront_api.cors_origin per tenant

7. Keamanan / Security

Berlapis, *defense-in-depth* (seluruhnya terimplementasi):

- **Transport.** Browser→storefront HTTPS (Caddy). BFF→Odoo melalui TLS sidecar `storefront-tls` dengan *certificate pinning*.
- **Session.** Token customer di **HttpOnly cookie** (tak pernah di JS), **disegel AES-256-GCM** (`sealToken` / `openToken`); BFF menyuntik Bearer server-side dan *refresh* transparan; refresh token disimpan hashed; `openToken` *fail-closed*.
- **PII at-rest.** `phone/street/street2/zip` **Fernet-encrypted** (`ENC::` envelope) via `custom.ir.config.encrypt_value/decrypt_value`; `email` / `name` tetap plaintext (kunci identitas). *Trade-off*: field ini tidak lagi searchable/groupable di back-office.
- **Application.** Strict CSP + security headers (`X-Frame-Options: DENY`, `nosniff`, `Referrer-Policy`, `Permissions-Policy`, HSTS, COOP); HTML sanitization (DOMPurify); image proxy dikunci ke `^web/image/` (anti-SSRF); rate-limit (login/register/guest 8/min, newsletter 5/min, refresh 30/min) + body cap 64 KB; anti-IDOR ownership check alamat; ORM only (no raw SQL); consent UU PDP.
- **Secrets.** JWT signing key, HMAC secret, cookie-seal key, Fernet master key di-eksternalisasi via `environment/secret config`; prosedur rotasi terdokumentasi.

8. 3D PDP — Teknis / Technical

- **Library.** three.js + @react-three/fiber + drei; `ProductViewer.tsx` (lazy, SSR off).
- **Render.** Gambar produk dipetakan ke *mesh* kain (sine-drape), drag-rotate via `PresentationControls`, contact shadow + environment HDRI self-hosted (`/env/studio_small_03_1k.hdr`), bump map prosedural.
- **CSP-safe.** Tidak ada fetch tekstur eksternal — gambar melalui proxy `/api/img`.
- **Fallback.** Toggle ke galeri foto 2D.

9. AI Personal Shopper — Teknis / Technical

- **Alur (retrieval-controlled, non tool-calling):** `EXTRACT` intent (JSON-mode) → `CLARIFY` bila terlalu umum → `RETRIEVE` produk dari Odoo `/storefront/api/products` *di kode* → `SYNTHESIZE` balasan natural → `GUARD` (kartu produk hanya dari payload katalog) → `ESCALATE` ke manusia (WhatsApp) untuk komplain/retur.
- **Provider.** Anthropic Claude (Haiku intent / Sonnet synthesis, prompt caching) atau Ollama lokal (`qwen2.5:7b` / `llama3.2:3b`).
- **Batas.** Max history 8 turn; reply ≤ 500 token; rate limit 12 req/min/IP.
- **Privasi.** Profil pengunjung (umur, warna, ukuran, budget) consent-gated, retensi terbatas, hak hapus.

10. Internasionalisasi / Internationalization

URL-prefixed locale (/id , /en) via `middleware.ts` ; field translatable Odoo mendorong konten katalog/editorial (?lang=); UI string via dictionary; OG tag terlokalisasi per URL.

`custom_material_composition` = `Text(translate=True)` (model-translation), set via `update_field_translations` .

11. Deployment & Operasi / Deployment & Operations

- **Containerisasi.** Docker Compose: `storefront` , `storefront-tls` , `odoo` , `postgres` , `redis` , `caddy` , `nginx` , `ai-gateway` .
- **Build storefront.** Image produksi *baked* (read-only FS); deploy = rebuild + recreate.
- **Perubahan modul Odoo.** Per-tenant: `-u <module> -d gentlewoman` (restart container Odoo untuk method Python baru).
- **Isolasi tenant.** Seluruh perubahan storefront ter-scope ke `gentlewoman` ; tenant lain tidak terpengaruh (verified).
- **Observability.** Health check storefront & Odoo; logging/metrics via platform (Prometheus/Grafana/Loki).
- **Seed data per tenant** via script (store, promo pricelist, drop date, stock quant) — **bukan** module data file (akan men-seed semua tenant saat upgrade).

12. Performa & Skala / Performance & Scaling

- Storefront *stateless* → horizontally scalable di belakang proxy.
- Pembacaan katalog cache-friendly; image delivery via proxy same-origin.
- Rate-limiter saat ini in-memory (single instance) — pindah ke Redis untuk multi-instance.

13. Dependensi & Batasan / Dependencies & Constraints

- **Payment (Eraspace): BLOCKED** menunggu dokumentasi API vendor. Checkout dibangun sampai pembuatan order di belakang interface `PaymentProvider` + *feature flag*.
- **AI (Fase 3 lanjutan):** memerlukan layanan AI eksternal + anggaran operasi; bukan jalur kritis peluncuran.
- Enkripsi memerlukan master/seal key platform tersedia & dirotasi sesuai kebijakan.

14. Kebutuhan Non-Fungsional / Non-Functional Requirements

Aspek	Target
Availability	Mengikuti SLA platform (target 99.5%)
Security	Checklist transport/session/at-rest/app-layer terpenuhi
Privacy	Kepatuhan UU PDP (consent, retensi, hak akses/hapus)
Tenant isolation	DB-per-tenant; tenant lain tidak terpengaruh
i18n	ID & EN penuh pada katalog & UI
Maintainability	Namespace <code>custom_</code> ; module knowledge file dijaga

15. Acceptance (Technical)

- Seluruh journey Fase-1 lulus *end-to-end* di atas stack terenkripsi.
- Checklist keamanan terpenuhi (transport, session, at-rest, app-layer).
- Isolasi tenant terkonfirmasi; tenant lain tidak terpengaruh.
- Dokumentasi (set ini) dijaga bersama module knowledge file.

Appendix A — Environment & Ports

Variable	Purpose
ODOO_BASE_URL / STOREFRONT_ODOO_BASE_URL	Endpoint Odoo (https → TLS sidecar)
ODOO_TENANT_DB / ODOO_TENANT_HOST	gentlewoman / host yang cocok dengan dbfilter
STOREFRONT_HMAC_SECRET	HMAC BFF↔Odoo (≡ ir.config_parameter)
STOREFRONT_COOKIE_KEY	Kunci seal cookie (fallback ke HMAC secret)
AI_GATEWAY_URL / GATEWAY_SHARED_SECRET	Endpoint + HMAC ai-gateway
NEXT_PUBLIC_ODOO_PUBLIC_URL / NEXT_PUBLIC_SITE_NAME / NEXT_PUBLIC_CURRENCY	Konfigurasi publik (IDR)

Service	Port
storefront (Next.js)	8080 (internal) → 443 via Caddy
odoo	8069
ai-gateway	8080 (internal)